MINOR PROJECT ASSESSMENT

API & ANDROID SECURITY — August Batch

Total Marks: 100 **Mode:** Practical + Scenario-Based

SECTION A — API SECURITY & crAPI

Q1. API Reconnaissance & Attack Surface Mapping — 15 Marks
Using crAPI or an equivalent authorized lab, identify and document at least 8 API endpoints. For each endpoint, record the HTTP method, path, authentication requirement, important parameters, and what security function it appears to perform. Identify at least 3 endpoints that deserve deeper authorization testing.

Q2. API Vulnerability Assessment — 15 Marks
Perform security testing against the authorized API lab. Identify any two API security weaknesses you can demonstrate (for example: improper authorization, excessive data exposure, weak input validation, or insecure business logic). For each finding, provide: endpoint, request/response evidence, steps to reproduce, impact, and remediation.

Q3. crAPI Practical Investigation — 10 Marks
Choose one realistic attack path in crAPI that involves multiple API requests. Map the complete flow from initial discovery to the security impact. Explain which request/parameter changed the application behavior and include sanitized evidence.

SECTION B — BROKEN ACCESS CONTROL / BOLA

Q4. BOLA Scenario — 10 Marks
You are authenticated as User A. While testing an API, you observe a request such as GET `/api/users/102/profile`. When the object ID is changed to another valid ID, the server returns another user's profile information. As a pentester, explain how you would safely verify whether this is BOLA, what evidence you would collect, the business impact, and the recommended fix.

Q5. Authorization Testing — 10 Marks
Design a small authorization test matrix for two users with different privileges. Test whether User A can read, modify, or delete objects belonging to User B. Explain how you would distinguish authentication from authorization failures and document the result without accessing unnecessary data.

SECTION C — OTP / AUTHENTICATION BYPASS

Q6. OTP Bypass Investigation — 10 Marks
During testing of an authorized application, the OTP verification workflow appears to accept an altered request or allows the verification step to be skipped. Explain your investigation methodology: map the normal OTP flow, identify which server-side controls should exist, test the suspected weakness safely, and collect evidence. State the security impact and controls required to prevent the bypass.

Q7. Authentication Security Review — 5 Marks
List and explain five security controls that should be implemented around OTP-based authentication, including server-side validation, expiry, attempt limits, replay protection, and secure session/token handling.

SECTION D — ANDROID APK & JADX ANALYSIS

Q8. APK Reconnaissance with JADX — 10 Marks
Analyze an authorized Android APK using JADX. Identify application components, interesting classes/packages, API endpoints, configuration values, and any hardcoded secrets or sensitive information that are exposed in the decompiled code. Create a short evidence table containing finding, location/class, sensitivity, and recommended action.

© 2025 UnloxAcademy. All Rights Reserved.
Made by recycled paper, because we care.

Q9. APK Leak Scenario — 5 Marks
JADX reveals an API key/token-like value and a production API endpoint inside an APK. Explain how you would determine whether the value is actually sensitive and still valid without abusing it. Discuss the potential impact and how the developer should remediate the issue.

SECTION E — PENTESTER DECISION-MAKING

Q10. Integrated Scenario — 10 Marks
You are testing an authorized mobile application's backend. You discover an APK containing a hidden API endpoint. The endpoint uses an object ID, and changing the ID exposes another user's data. The same application also contains an OTP verification flow with suspicious client-side logic. Build a professional testing plan showing the order in which you would investigate these issues, what evidence you would capture, how you would avoid unnecessary data exposure, and how you would report the findings with severity and remediation.

SUBMISSION REQUIREMENTS

• Submit a concise technical report with screenshots/evidence from the authorized lab only.

• Every vulnerability must include: title, affected endpoint/component, description, reproduction steps, evidence, impact, and remediation.

• Do not include real user data, real production credentials, or unauthorized targets.

• Where a vulnerability cannot be safely exploited, demonstrate the security weakness using a controlled lab proof-of-concept.

• Recommended tools: Burp Suite, browser/dev tools, crAPI, JADX, APK analysis utilities, and any supporting command-line tools.

Section	Marks
API Security & crAPI	40
Broken Access Control / BOLA	20
OTP / Authentication Bypass	15
Android APK & JADX	15
Pentester Decision-Making	10
TOTAL	**100**

© 2025 UnloxAcademy. All Rights Reserved.
Made by recycled paper, because we care.